

Отчёт по анализу приложения SupportDesk

1. Общая информация

SupportDesk — десктопное Windows-приложение (WinForms) для внутренней технической поддержки организации (упоминается «КООР» / «Technical support КООР»).

Параметр	Значение
Тип	WinExe (Windows Forms)
Платформа	.NET Framework 4.8
Язык	C#
БД	SQLite (teh_db.db , локальный файл)
Объём кода	~23 200 строк C# (включая Designer)
Дата последних изменений в архиве	2023 (сентябрь)
Архитектура	Монолитный WinForms-проект с большим количеством форм

Точка входа: PreLoaderForm → проверка/создание служебных папок и файлов
→ LoginForm .

2. Назначение и функциональность

Приложение реализует полноценный **Service Desk / Help Desk** с ролевой моделью:

Роли

- **USER** — обычный пользователь (создание заявок, просмотр своих данных)
- **Worker / Executor** — исполнитель (работа с заявками, картриджами и т.д.)
- **ADMIN** — полный доступ (пользователи, справочники, отчёты, настройки)

Основные модули

1. Система заявок (Requests / Tickets)

Создание, назначение исполнителей, смена статуса, вложения, результат закрытия, история.

2. **Учёт пользователей**
Регистрация, редактирование, блокировка, аватары, группы, отделы, должности.
3. **Инвентаризация**
Оборудование (название, инв. номер, дата покупки, количество, местоположение).
4. **Лицензии ПО**
Привязка к кабинетам, проверка, PDF-документы.
5. **Картриджи / принтеры**
Учёт замен по кабинетам и датам (до 8 дат замен).
6. **Хранилище паролей**
Сайты / логины / пароли (открытым текстом).
7. **Контакты**
Компании, ФИО, телефоны.
8. **Справочники**
Кабинеты, типы работ, отделы, должности, статусы, исполнители.
9. **Интеграции**
 - Telegram-бот (уведомления о всех ключевых действиях)
 - Email (восстановление доступа через mail.ru / yandex.ru)
 - Excel (отчёты через Microsoft.Office.Interop.Excel)
10. **Дополнительно**
Календарь заявок, виджеты на главном экране, логирование действий, «запомнить пароль».

3. Технологический стек

- **UI:** System.Windows.Forms + кастомные контролы (ExpUIButton , ExpUICheckBox , textBoxUI и др.)
- **БД:** System.Data.SQLite 1.0.117
- **JSON:** Newtonsoft.Json 13.0.2
- **Telegram:** Telegram.Bot 16.0.0
- **Excel:** Microsoft.Office.Interop.Excel 15.0
- **Прочее:** System.ComponentModel.Annotations, System.Threading.Tasks.Extensions

Конфигурация хранится в статических классах в Program.cs (таблицы, лимиты, настройки виджетов, email, Telegram и т.д.).

4. Структура базы данных (по коду)

Основные таблицы:

- `Users` — пользователи (ФИО, пол, телефон, email, отдел, должность, login, **pass**, groupUser, image, typeAccess)
- `Requests` — заявки (дата, тема, тип, пользователь, кабинет, описание, статус, исполнители, файлы)
- `Inventory` — инвентарь
- `Licenses` — лицензии
- `Cartridges` — картриджи/принтеры
- `Passwords` — пароли
- `Contacts` — контакты
- `Cabinets`, `TypeJob`, `Departaments`, `Positions`, `Status`, `Executors` — справочники

Лимиты (защиты в код): 500 пользователей, 5000 единиц техники, 15 исполнителей.

5. Критические проблемы безопасности (высокий приоритет)

Проблема	Описание	Риск
SQL-инъекция	В <code>LoginForm</code> запрос формируется конкатенацией строк: <code>WHERE login = '' + TextBoxLogin.Text + '' AND pass = '' + TextBoxPassword.Text + ''</code> . Хотя в других местах часто используются параметры.	Высокий — возможен полный доступ к БД
Пароли в открытом виде	Хранятся и сравниваются в plaintext в таблице <code>Users</code> и в таблице <code>Passwords</code> .	Критический
Hardcoded secrets	• Root-пароль: <code>K00pt3hR00t4cce\$\$</code> • Telegram bot token: <code>1803354166:AAGHbBN9JxLQW_TfMxRbIaEQ5_vTCTmSsB0</code> • Email-логины/пароли (mail.ru и yandex.ru) • ID канала и админа Telegram	Критический — токены и пароли можно извлечь из бинарника

Отправка паролей в Telegram	При регистрации нового пользователя пароль уходит открытым текстом в Telegram-канал.	Критический
Файл «запомнить пароль»	SupportDesk\loginPassword.txt — логин:пароль в открытом виде.	Высокий
Слабая политика паролей	Есть только blacklist простых паролей (123456 , qwerty и т.д.). Нет требований к длине/сложности при создании.	Средний
Локальная SQLite без шифрования	Файл teh_db.db лежит рядом с приложением.	Высокий при доступе к диску
Устаревшие протоколы	В TelegramForm включается SecurityProtocolType.Ssl3 (и старые TLS).	Средний

6. Архитектурные и качественные замечания

Плюсы:

- Понятная ролевая модель
- Довольно полный набор функций для небольшого/среднего ИТ-отдела
- Использование параметров в большинстве запросов (кроме логина)
- Кастомный UI и скрытые служебные папки
- Логирование действий в logs.txt

Минусы:

- Монолит: почти вся логика в формах + огромный Program.cs со статическими классами-конфигами
- Много дублирования кода (особенно в Designer-файлах и обработчиках перемещения окна)
- [Obsolete] -атрибуты на многих методах
- Нет миграций БД / создания схемы в коде (предполагается, что teh_db.db уже существует)
- Отсутствие шифрования, аудита доступа, 2FA
- Жёстко зашитые лимиты и пути
- Смешение UI и бизнес-логики

- Использование `Microsoft.Office.Interop.Excel` (требует установленного Excel)

7. Рекомендации

Немедленные (безопасность)

1. Переписать логин на параметризованный запрос.
2. Хешировать пароли (минимум PBKDF2 / bcrypt / Argon2).
3. Вынести все секреты (токены, email, root-пароль) в защищённое хранилище / переменные окружения / encrypted config.
4. Прекратить отправку паролей в Telegram.
5. Шифровать файл «запомнить пароль» или отказаться от него.
6. Добавить SQLCipher или аналог для SQLite.

Среднесрочные

- Вынести бизнес-логику в сервисы / репозитории.
- Добавить создание и миграции схемы БД.
- Обновить Telegram.Bot и убрать устаревшие TLS/SSL.
- Реализовать нормальную политику паролей и блокировку после N попыток.
- Добавить аудит (кто что менял).

Долгосрочные

- Рассмотреть переход на .NET 8 + WPF/WinUI или веб-версию (Blazor / ASP.NET).
- Разделить на клиент + сервер (сейчас всё локально).

8. Заключение

SupportDesk — функциональное локальное приложение для учёта заявок, инвентаря, лицензий и паролей, написанное под конкретную организацию. Оно закрывает основные потребности небольшого ИТ-отдела, но имеет **критические уязвимости безопасности** (plaintext-пароли, SQL-инъекция, hardcoded secrets, утечка паролей в Telegram).

В текущем виде приложение **не рекомендуется** к использованию в production без серьёзной доработки безопасности. Приоритет — исправление аутентификации и хранилища паролей.

Если нужно углубиться в конкретный модуль (например, полный разбор заявок, схему БД. или предложения по рефакторингу) — уточните.